

Security Patch Report – AdForest Phone-Based Login

This document outlines the security improvements made to the AdForest theme's phone-based login functionality. The updates address a reported vulnerability that allowed unauthorized account takeover via chained requests exploiting insecure access to phone number data and OTP-based login endpoints.

Issue Summary & Resolution

- Phone number disclosure via ``sb_display_phone_num_profile_callback``
 - Removed unauthenticated access to the callback.
 - Now requires a logged-in user.
- User enumeration via ``sb_login_check_user_func``
 - No longer reveals whether a phone number is registered.
 - Always responds with a generic success message.
- User ID manipulation & session takeover
 - The function no longer accepts ``user_id`` from the client.
 - Secure token is generated and stored in the server session and user meta.
- Session hijacking risk
 - The session token must match the stored user meta token.
 - Token is removed after a single use.
- Lack of rate limiting
 - Rate limiting is enforced based on IP address using WordPress transients.
 - After 5 failed attempts, further attempts are blocked for 15 minutes.
- Missing input sanitization
 - All input fields are sanitized using ``sanitize_text_field()``.
- Lack of nonce validation
 - Nonce checks are enforced on all AJAX requests.

Frontend Adjustments

The frontend OTP login flow was preserved with the following minor adjustments:

- The ``user_id`` is no longer sent via AJAX.
- Secure login depends on session tokens handled entirely server-side.
- Phone validation messages were generalized to prevent enumeration.

Exploit Chain Resolution

Previously, an unauthenticated attacker could:

1. Leak a user's phone number via public AJAX.
2. Use it to trigger login and extract `user\_id` and secure token.
3. Bypass verification and gain unauthorized access.

Now, all of these steps are prevented:

- Phone numbers are only accessible if user is logged in.
- Login logic is generic and does not expose user existence.
- Secure tokens are never exposed to the frontend.
- Session validation is enforced on the server side.

Conclusion

All reported issues have been fully addressed. The implementation now protects against unauthorized access, user enumeration, and phone-based account takeovers. The patch aligns with WordPress plugin security best practices and is ready for review and resubmission.